Chapter 5

E-Commerce Security and Fraud Protection

Learning Objectives

1. Understand the importance and scope of the security of information systems for EC.
2. Describe the major concepts and terminology of EC security.
3. Learn about the major EC security threats, vulnerabilities, and risks.
4. Understand phishing and its relationship to financial crimes.
5. Describe the information assurance security principles.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Learning Objectives

6. Identify and assess major technologies and methods for securing EC communications.
7. Describe the major technologies for protection of EC networks.
8. Describe various types of controls and special defense mechanisms.
9. Describe the role of business continuity and disaster recovery planning.
10. Discuss EC security enterprise-wide implementation issues.
11. Understand why it is not possible to stop computer crimes.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Security Problem

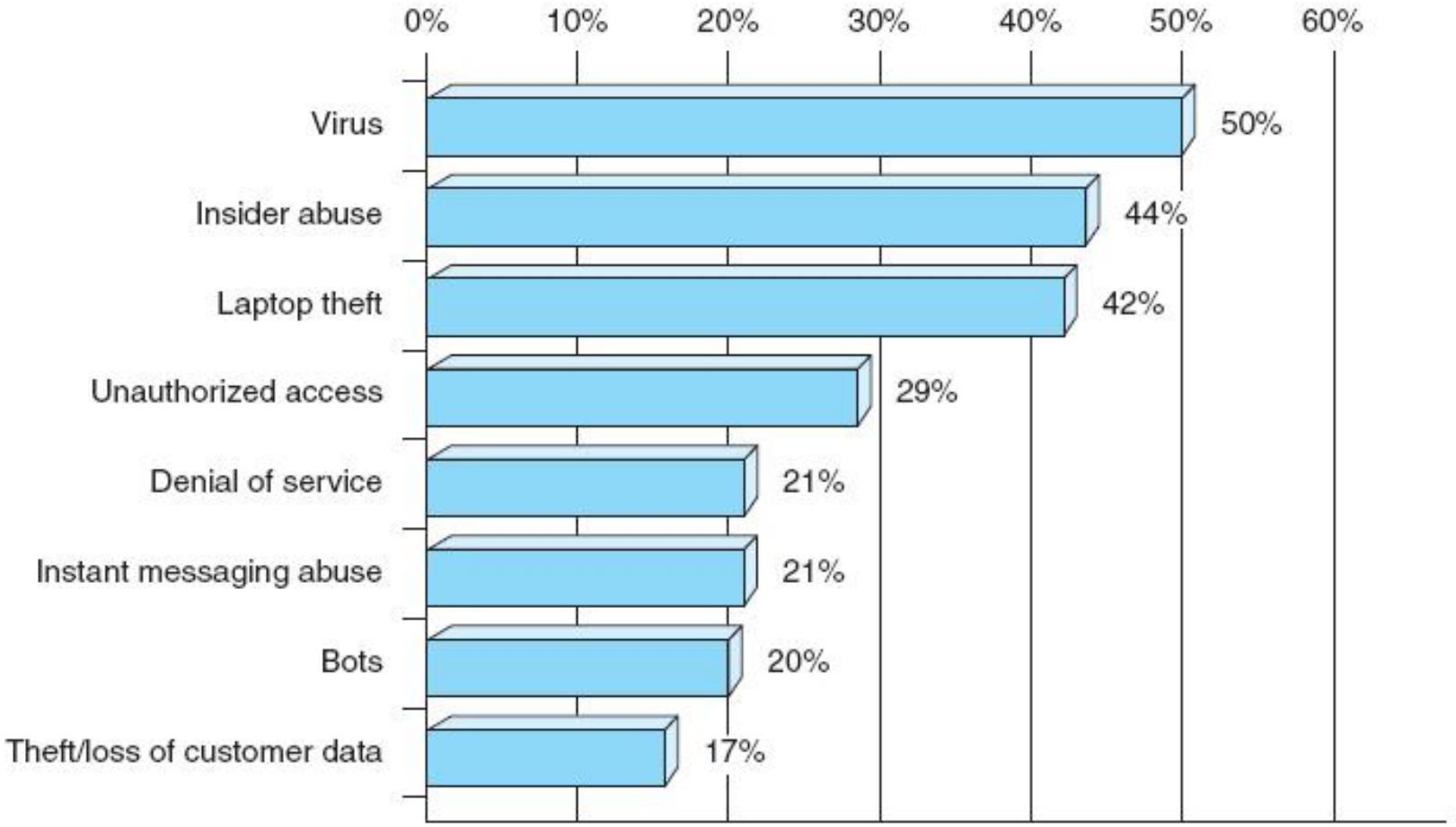
- **WHAT IS EC SECURITY?**
  - *Computer security* refers to the protection of data, networks, computer programs, computer power, and other elements of computerized information systems
- **THE DRIVERS OF EC SECURITY PROBLEMS**
  - **The Internet's Vulnerable Design**
    - **domain name system (DNS)**

      Translates (converts) domain names to their numeric IP addresses.
    - **IP address**

      An address that uniquely identifies each computer connected to a network or the Internet.
  - **The Shift to Profit-Induced Crimes**

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

EXHIBIT 9.1 Major Computer Attack Incidents in 2008



Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Security Problem

- **Internet underground economy**

  E-markets for stolen information made up of thousands of Web sites that sell credit card numbers, social security numbers, other data such as numbers of bank accounts, social network IDs, passwords, and much more.

  - **keystroke logging (keylogging)**

    A method of capturing and recording user keystrokes.

- **The Dynamic Nature of EC Systems and the Role of Insiders (many newcomers)**

- **WHY IS E-COMMERCE SECURITY STRATEGY NEEDED?**
  - **The Computer Security Dilemma**
    - **IS Departments with heavy workload and small budgets can't optimize security programs.**

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Basic E-Commerce Security Issues and Landscape

- **THE SECURITY BASIC TERMINOLOGY**
  - **business continuity plan**

    A plan that keeps the business running after a disaster occurs. Each function in the business should have a valid recovery capability plan.
  - **cybercrime**

    Intentional crimes carried out on the Internet.
  - **exposure**

    The estimated cost, loss, or damage that can result if a threat exploits a vulnerability.
  - **fraud**

    Any business activity that uses deceitful practices or devices to deprive another of property or other rights.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Basic E-Commerce Security Issues and Landscape

- **malware (malicious software)**

  A generic term for malicious software.

- **phishing**

  A crimeware technique to steal the identity of a target company to get the identities of its customers.

- **risk**

  The probability that a vulnerability will be known and used.

- **social engineering**

  A type of nontechnical attack that uses some ruse to trick users into revealing information or performing an action that compromises a computer or network.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Basic E-Commerce Security Issues and Landscape

- **spam**

  The electronic equivalent of junk mail.

- **vulnerability**

  Weakness in software or other mechanism that threatens the confidentiality, integrity, or availability of an asset (Called the CIA model). It can be directly used by a hacker to gain access to a system or network.

- **zombies**

  Computers infected with malware that are under the control of a spammer, hacker, or other criminal.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Basic E-Commerce Security Issues and Landscape

- **Threats and Attacks: Unintentional and Intentional**
  - Unintentional Threats
    - Human error
    - Environmental hazards
    - Malfunctions in the computer system
  - Intentional Attacks and Crimes
    - Theft, misuse, manipulation of data
    - Theft of laptops
    - Internet Fraud

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Basic E-Commerce Security Issues and Landscape

- **Criminals and Social Engineering**
  - **cybercriminal**

    A person who intentionally carries out crimes over the Internet.
  - **hacker**

    Someone who gains unauthorized access to a computer system.
  - **cracker**

    A malicious hacker, such as Maxwell in the opening case, who may represent a serious problem for a corporation.
- **Vulnerable Areas Are Being Attacked**
  - PCs, Users, Networks, DBs can be attacked

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Basic E-Commerce Security Issues and Landscape

- **EC Security Requirements**
  - **authentication**

    Process to verify (assure) the real identity of an individual, computer, computer program, or EC Web site.
  - **authorization**

    Process of determining what the authenticated entity is allowed to access and what operations it is allowed to perform.
  - Auditing : recording information about any access
  - Availability : example is load-balancing
  - **nonrepudiation**

    Assurance that online customers or trading partners cannot falsely deny (repudiate) their purchase or transaction. Used against phishing and identity theft

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Basic E-Commerce Security Issues and Landscape

- **THE DEFENSE: DEFENDERS AND THEIR STRATEGY**
  - **EC security strategy**

    A strategy that views EC security as the process of preventing and detecting unauthorized use of the organization's brand, identity, Web site, e-mail, information, or other asset and attempts to defraud the organization, its customers, and employees.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Basic E-Commerce Security Issues and Landscape

- **deterring measures**

  Actions that will make criminals abandon their idea of attacking a specific system (e.g., the possibility of losing a job for insiders).

- **prevention measures**

  Ways to help stop unauthorized users (also known as “intruders”) from accessing any part of the EC system. Ex: requiring passwords

- **detection measures**

  Ways to determine whether intruders attempted to break into the EC system, whether they were successful, and what they may have done.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Basic E-Commerce Security Issues and Landscape

- **information assurance (IA)**

  The protection of information systems against unauthorized access to or modification of information whether in storage, processing, or transit, and against the denial of service to authorized users, including those measures necessary to detect, document, and counter such threats.

- **Defense Methods and Technologies**

  - Recovery : is done by business continuity plan

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Technical Attack Methods

- **TECHNICAL AND NONTECHNICAL ATTACKS: AN OVERVIEW**
  - Software and systems knowledge are used to perpetrate *technical attacks* (computer virus)
  - *Nontechnical attacks* are those in which a perpetrator uses some form of deception or persuasion to trick people into revealing information or performing actions that can compromise the security of a network

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Technical Attack Methods

- **MALICIOUS CODE**
  - **virus**

    A piece of software code that inserts itself into a host, including the operating systems, in order to propagate; it requires that its host program be run to activate it.
  - **worm**

    A software program that runs independently, consuming the resources of its host in order to maintain itself, that is capable of propagating a complete working version of itself onto another machine. It can spread without human intervention

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Technical Attack Methods

- **Trojan horse**

  A program that appears to have a useful function but that contains a hidden function that presents a security risk.

- **banking Trojan**

  A Trojan that comes to life when computer owners visit one of a number of online banking or e-commerce sites.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Technical Attack Methods

- **denial of service (DoS) attack**

  An attack on a Web site in which an attacker uses specialized software to send a flood of data packets to the target computer with the aim of overloading its resources.
- **Web Server and Web Page Hijacking**
- **botnet**

  A huge number (e.g., hundreds of thousands) of hijacked Internet computers that have been set up to forward traffic, including spam and viruses, to other computers on the Internet.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Phishing, Financial Fraud, and Spam

- **FRAUD ON THE INTERNET**
  - **phishing**

    A crimeware technique to steal the identity of a target company to get the identities of its customers.
  - **identity theft**

    Fraud that involves stealing an identity of a person and then the use of that identity by someone pretending to be someone else in order to steal money or get other benefits.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Phishing, Financial Fraud, and Spam

- **SPAM AND SPYWARE ATTACKS**
  - **e-mail spam**

    A subset of spam that involves nearly identical messages sent to numerous recipients by e-mail.
  - **spyware**

    Software that gathers user information over an Internet connection without the user's knowledge.

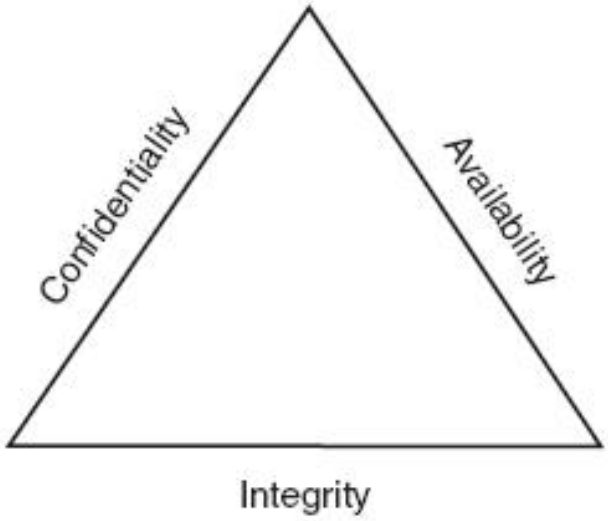
Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Assurance Model and Defense Strategy

- **CIA security triad (CIA triad)**

  Three security concepts important to information on the Internet: confidentiality, integrity, and availability.

EXHIBIT 9.7 CIA Security Triad



Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Assurance Model and Defense Strategy

- **confidentiality**

  Assurance of data privacy and accuracy. Keeping private or sensitive information from being disclosed to unauthorized individuals, entities, or processes.

- **integrity**

  Assurance that stored data has not been modified without authorization; a message that was sent is the same message as that which was received.

- **availability**

  Assurance that access to data, the Web site, or other EC data service is timely, available, reliable, and restricted to authorized users.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Assurance Model and Defense Strategy

- **E-COMMERCE SECURITY STRATEGY**
  1. Prevention and deterrence
  2. Detection
  3. Containment (contain the damage)
  4. Recovery
  5. Correction
  6. Awareness and compliance

- **EC security programs**

  All the policies, procedures, documents, standards, hardware, software, training, and personnel that work together to protect information, the ability to conduct business, and other assets.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Assurance Model and Defense Strategy

- **access control**

  Mechanism that determines who can legitimately use a network resource.

  - **Authentication and Passwords**
  - **biometric control**

    An automated method for verifying the identity of a person based on physical or behavioral characteristics.
  - **biometric systems**

    Authentication systems that identify a person by measurement of a biological characteristic, such as fingerprints, iris (eye) patterns, facial features, or voice.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Assurance Model and Defense Strategy

- **ENCRYPTION**
  - **encryption**

    The process of scrambling (encrypting) a message in such a way that it is difficult, expensive, or time-consuming for an unauthorized person to unscramble (decrypt) it.
  - **plaintext**

    An unencrypted message in human-readable form.
  - **ciphertext**

    A plaintext message after it has been encrypted into a machine-readable form.
  - **encryption algorithm**

    The mathematical formula used to encrypt the plaintext into the ciphertext, and vice versa.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Assurance Model and Defense Strategy

- **firewall**

  A single point between two or more networks where all traffic must pass (choke point); the device authenticates, controls, and logs all traffic.

  – **packet**

    Segment of data sent from one computer to another on a network.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Assurance Model and Defense Strategy

- **intrusion detection system (IDS)**

  A special category of software that can monitor activity across a network or on a host computer, watch for suspicious activity, and take automated action based on what it sees.
- **honeypot**

  Production system (e.g., firewalls, routers, Web servers, database servers) that looks like it does real work, but that acts as a decoy and is watched to study how network intrusions occur.
- **penetration test (pen test)**

  A method of evaluating the security of a computer system or a network by simulating an attack from a malicious source, (e.g., a cracker).

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

The Information Assurance Model and Defense Strategy

- **general controls**

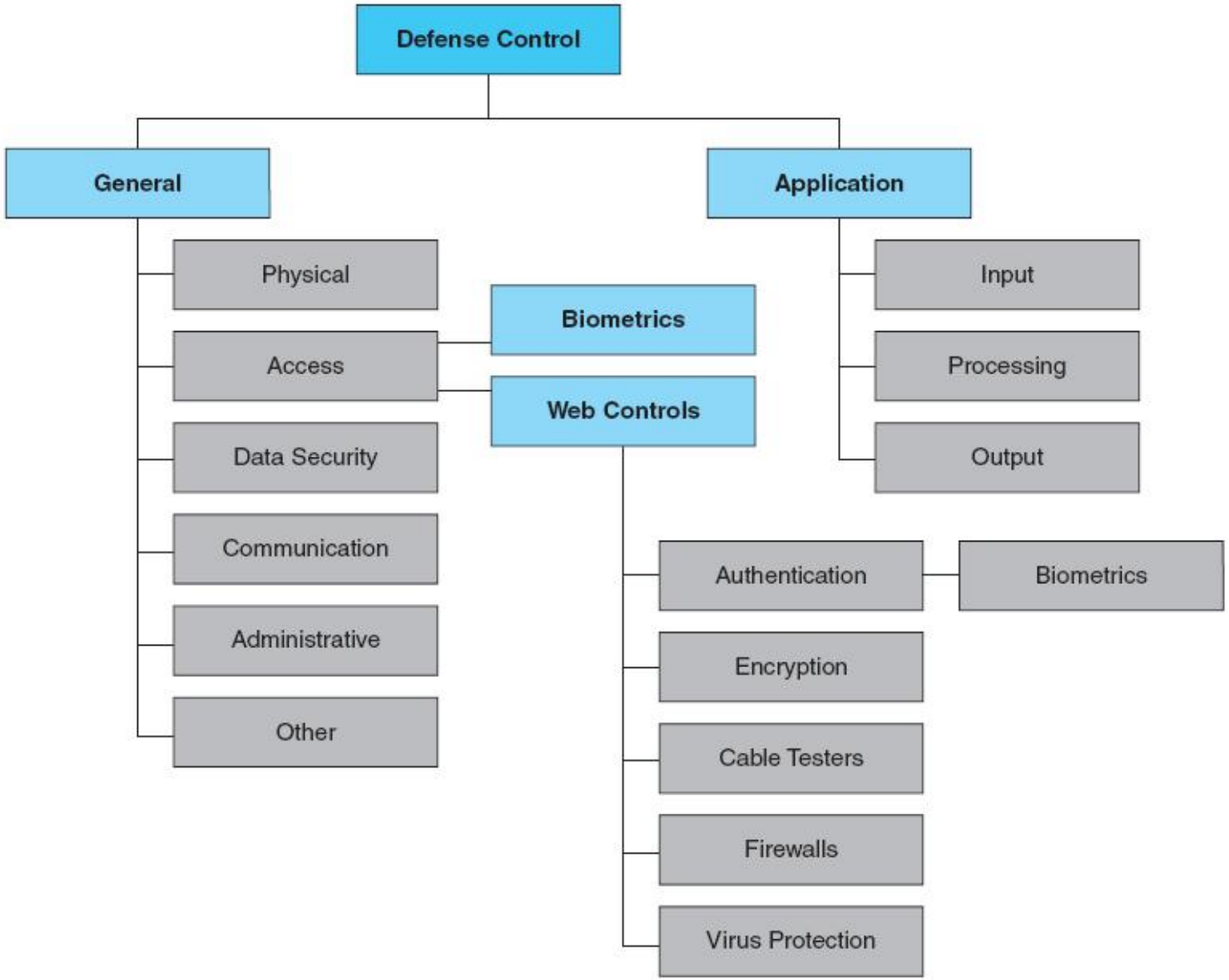
  Controls established to protect the system regardless of the specific application. For example, protecting hardware and controlling access to the data center are independent of the specific application. Ex: physical and administrative controls.

- **application controls**

  Controls that are intended to protect specific applications.

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

EXHIBIT 9.12 Major Defense Controls



Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Business Continuity, Security Auditing, and Risk Management

- **BUSINESS CONTINUITY AND DISASTER RECOVERY PLANNING**
  - **disaster avoidance**

    An approach oriented toward prevention. The idea is to minimize the chance of avoidable disasters (such as fire or other human-caused threats).
- **RISK-MANAGEMENT**
- **COST-BENEFIT ANALYSIS**

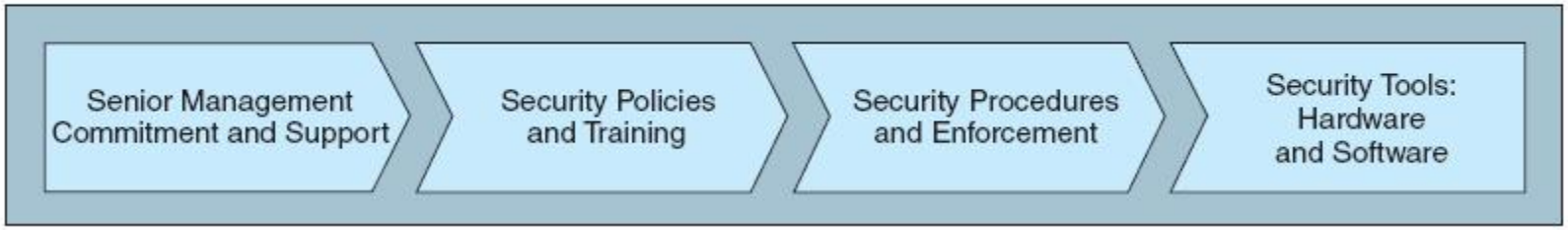
Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Implementing Enterprise-Wide E-Commerce Security

- **SENIOR MANAGEMENT COMMITMENT AND SUPPORT**
- **EC SECURITY POLICIES AND TRAINING**
  - **acceptable use policy (AUP)**

    Policy that informs users of their responsibilities when using company networks, wireless devices, customer data, and so forth.

EXHIBIT 9.16 Enterprise-wide EC Security and Privacy Model



Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall

Implementing Enterprise-Wide E-Commerce Security

- **WHY IS IT DIFFICULT TO STOP INTERNET CRIME?**
  - **Making Shopping Inconvenient**
  - **Shoppers' Negligence**
  - **Ignoring EC Security Best Practices**
  - **Design and Architecture Issues**
  - **standard of due care**

    Care that a company is reasonably expected to take based on the risks affecting its EC business and online transactions.

    - hiring criminals
    - outsource to fraudulent vendor
    - partner with unsecured companies

Copyright © 2011 Pearson Education, Inc.
Publishing as Prentice Hall